

DMARC Protocol Explained

What is DMARC?

- Domain-based Message Authentication, Reporting & Conformance
- A policy framework that helps prevent email spoofing and phishing by combining SPF and DKIM
- Tells receiving mail servers how to handle emails that fail authentication checks

Key Components

SPF

Sender Policy Framework

- Verifies sending server IP
- Published in DNS TXT record

DKIM

Domain Keys Identified Mail

- Cryptographic signature that verifies part of the message content and headers, using the sender's domain

Alignment

SPF Alignment

"MAIL" from domain must match the "FROM" header domain

DKIM Alignment

DKIM "d=" domain must match the "FROM" header domain

DMARC Policies

p=none

- Monitor mode, no enforcement
- Recommended for initial setup

p=quarantine

- Flag emails that fail (spam folder)

p=reject

- Block emails that fail completely

DMARC Record Format (DNS TXT Record)

`v=DMARC1; p=reject; rua=mailto:dmarc-reports@example.com; pct=100; adkim=s; aspf=s`

- v=DMARC1: Protocol version
- p= Policy (none, quarantine, reject)
- pct = Percentage of messages subject to filtering
- rua= Reporting URI for aggregate reports
- adkim = DKIM alignment mode (s=strict, r=relaxed)
- aspf= SPF alignment mode (s=strict, r=relaxed)

DMARC Evaluation Examples

DMARC PASS

FROM: someone@domain.com

SPF CHECK

PASS ALIGN

MAIL FROM: other@domain.com

DKIM CHECK

PASS ALIGN

DKIM-Signature: d=domain.com

DMARC FAIL

FROM: someone@domain.com

SPF CHECK

PASS ALIGN

MAIL FROM: other@domain.com

DKIM CHECK

PASS ALIGN

DKIM-Signature: d=domain.com

DMARC PASS

FROM: someone@domain.com

SPF CHECK

PASS ALIGN

MAIL FROM: other@domain.com

DKIM CHECK

PASS ALIGN

DKIM-Signature: d=domain.com

Important

Keep in mind, these technologies are really protecting others from you. This really only works if everyone is doing it. Nothing forces anyone to honr your DMRC, SPF or DKIM records, but it is in their best interest to ensure that they are not accepting spoofed emails.

D

/

M

/

A

/

R

/

C

(Domain-Based / Message / Authentication / Reporting / & Conformance)

DMARC EVALUATION

```
graph TD
    Sender[Sender Email Client] --> Message[Email Message]
    Message --> Recipient[Recipient Mail Server]
    Recipient --> Auth[Authentication Checks]
    Auth --> DKIM{DKIM Pass/Aligned?}
    Auth --> SPF{SPF Pass/Aligned?}
    DKIM -- No --> FailBox[SPF = Fail  
DKIM = Fail]
    DKIM -- Yes --> Policy{Policy Action?}
    SPF -- No --> FailBox
    SPF -- Yes --> DKIM2{DKIM Pass/Aligned?}
    DKIM2 -- No --> PassFail[SPF = Pass  
DKIM = Fail]
    DKIM2 -- Yes --> PassPass[SPF = Pass  
DKIM = Pass]
    FailBox --> Policy
    PassFail --> Policy
    Policy -- "If p=quarantine/reject" --> Action[Take DMARC Action  
(Quarantine, Reject, or Deliver anyway)  
and Report Message to RUA address.]
    Policy -- "If p=none" --> Deliver[Deliver the Message]
    Policy -- "Quarantine (apply to spam folder)" --> Deliver
    Policy -- "Drop Message" --> Drop[Drop Message]
```

The flowchart illustrates the DMARC evaluation process. It begins with an email message being sent from a Sender Email Client to a Recipient Mail Server. The server performs authentication checks on both DKIM and SPF. If either check fails, the process moves to a 'Policy Action?' decision point. If the policy is set to 'quarantine' or 'reject', the message is taken action upon (quarantined, rejected, or delivered anyway) and a report is sent to the RUA address. If the policy is 'none', the message is delivered. If the policy is 'quarantine' and the message is not rejected, it is quarantined (applied to the spam folder) before being delivered. A 'Drop Message' action is also shown as a possible outcome of the policy action.

sysxplore.com